08-Detection-Lifecycle-Checklist

Detection Lifecycle Checklist

Use this checklist for each detection gap identified during a Purple Team Exercise. Follow the steps sequentially from gap identification through production deployment and ongoing regression testing. Do not skip the validation or tuning steps.

Phase 1: Document the Gap

- ❑ Record the TTP, the gap category, and the outcome score in the exercise tracking system (PlexTrac, VECTR, JIRA, or equivalent)
- ❑ Document the telemetry that is available for this TTP (data sources, log fields, event IDs)
- ❑ Document the telemetry that is missing, if any
- ❑ Record the Red Team's execution details: exact commands, tools, parameters, and target systems
- ❑ Capture sample log entries or artifacts from the exercise (copy raw events for use as test data)
- ❑ If this is a Visibility Gap: create a separate work item for data source onboarding before proceeding

Detection Information

Field	Value
ATT&CK Technique ID	
Technique Name	
Source Exercise / Date	
Gap Category	Visibility / Detection Logic / Alert Suppression / Process / Timeliness
Graded Outcome Score	___ / 5
Detection Engineer (Owner)	
Priority Score (from prioritization framework)	
Target Completion Date	

Gate: Do not proceed to Phase 2 until the required telemetry is confirmed available in the SIEM or detection platform.

Phase 2: Design the Detection Rule

- ❑ Identify the target detection platform (SIEM, EDR, NDR, cloud-native, or multiple)
- ❑ Review MITRE D3FEND for applicable defensive techniques
- ❑ Review existing community rules for this technique:
  - ☐ SigmaHQ rule repository
  - ☐ EDR vendor rule library
  - ☐ Cloud-native detection catalog (GuardDuty, Sentinel, Chronicle)
- ❑ Author the detection rule specifying:
  - ☐ Detection logic (query, correlation, threshold)
  - ☐ Required data sources and log fields
  - ☐ Expected alert severity level
  - ☐ ATT&CK technique and tactic mapping
  - ☐ Alert title and description (clear enough for SOC analyst triage)
- ❑ Choose the rule format:
  - ☐ Sigma 2.0 (preferred for portability)
  - ☐ YARA (for file/memory scanning)

- [ ] Platform-native (when Sigma conversion is insufficient)
- [ ] Assess detection robustness using Summiting the Pyramid:
  - [ ] What level of the Pyramid of Pain does this detection target?
  - [ ] Can an adversary trivially evade it by changing a single indicator?
  - [ ] Can the detection be improved to target behaviors rather than artifacts?
- [ ] Store the rule in the version-controlled detection repository

---

Phase 3: Peer Review

- [ ] Submit the detection rule for peer review (pull request or equivalent)
- [ ] Reviewer confirms detection logic is correct and covers the intended behavior
- [ ] Reviewer checks for common mistakes:
  - [ ] Overly broad logic that will generate excessive false positives
  - [ ] Overly narrow logic that only catches the exact exercise variant
  - [ ] Missing fields or incorrect field names for the target platform
  - [ ] Hardcoded indicators (hashes, IPs) that should be behavioral patterns
- [ ] Reviewer approves or requests changes
- [ ] Address all review feedback and get final approval

Phase 4: Validate the Detection

- [ ] Deploy the rule to a staging or test environment (not production)
- [ ] Re-execute the TTP using the same procedure from the exercise (coordinate with Red Team or use an adversary emulation platform)
- [ ] Confirm the detection fires and generates an alert
- [ ] Verify the alert contains:
  - [ ] Correct severity level
  - [ ] ATT&CK mapping
  - [ ] Sufficient context for triage (source host, user, process, command line)
  - [ ] Timestamps that match the TTP execution time
- [ ] Execute variations of the TTP (different parameters, tools, or paths) to test detection breadth
- [ ] Document the true positive test results with timestamps and evidence

Gate: Do not proceed to Phase 5 until the detection fires correctly on at least the original TTP and one variation.

Phase 5: Tune for False Positives

- ❑ Run the detection against baseline environment activity (minimum 48-72 hours in staging, or against historical logs)
- ❑ Review all alerts generated during the baseline period
- ❑ For each false positive identified:
  - ▢ Document the legitimate activity triggering the rule
  - ▢ Create a targeted exception (as narrow as possible)
  - ▢ Record the exception with justification, date, and analyst name
  - ▢ Set a review date for the exception (quarterly at minimum)
- ❑ After adding exceptions, re-run the TTP to confirm the detection still fires
- ❑ Verify the false positive rate meets the threshold for the alert severity:
  - ▢ Critical: <5% FP rate
  - ▢ High: <15% FP rate
  - ▢ Medium: <30% FP rate
  - ▢ Low/Informational: <50% FP rate
- ❑ If FP rate exceeds threshold, refine logic and repeat this phase

Gate: Do not proceed to Phase 6 until FP rate is within threshold AND the detection still fires on the TTP.

Phase 6: Deploy to Production

- ❑ Push the validated, tuned detection to production through the CI/CD pipeline (or manual deployment process)
- ❑ Confirm the rule is active and enabled in the production platform
- ❑ Verify the alert routes to the correct SOC queue or dashboard
- ❑ Confirm alert enrichment is working (threat intel lookups, asset context, user context)
- ❑ Create or update the SOC response playbook for this detection:
  - ▢ Triage steps
  - ▢ Investigation queries
  - ▢ Escalation criteria
  - ▢ Containment actions
- ❑ Notify SOC analysts of the new detection and provide a brief walkthrough
- ❑ Run a final validation: execute the TTP in production (coordinated with Red Team) and confirm end-to-end detection and alert delivery

---

Phase 7: Add to Regression Testing

- ❑ Add the TTP and expected detection to the automated regression testing suite
- ❑ Configure the test to:

- [ ] Execute the TTP on a defined schedule (weekly minimum)
- [ ] Verify the detection fires within the expected timeframe
- [ ] Alert if the detection fails to fire (regression detected)

- [ ] If using a BAS platform, import the TTP into the platform library
- [ ] Confirm the first automated regression test passes
- [ ] Update the ATT&CK Navigator coverage layer:
  - [ ] Change the technique score from the pre-exercise baseline to the new validated state
  - [ ] Add a comment noting the exercise date and detection rule name

---

Phase 8: Close the Loop

- [ ] Update the exercise tracking system (PlexTrac, VECTR, JIRA) to mark the gap as remediated
- [ ] Record the final detection details:
  - [ ] Rule name and ID
  - [ ] Platform deployed to
  - [ ] Date deployed
  - [ ] Regression test schedule
- [ ] Include in the next knowledge transfer session with the broader Blue Team
- [ ] Notify the Exercise Coordinator that the gap is closed
